



Código do Documento: PI-SGSI-001

Versão: 01 | **Revisão:** 01

Total de Páginas: 18

Empresa Responsável: Security Solutions

Documento confidencial. Propriedade da Atlântica Financeira. Uso Interno Restrito

SUMÁRIO

1. **Objetivo**
2. **Âmbito / Abrangência**
3. **Definições**
4. **Papéis e Responsabilidades**
5. **Divulgação e Declaração das Responsabilidades**
6. **Classificação da Informação**
 - 6.1 Níveis de Classificação
 - 6.2 Propriedade da Informação
 - 6.3 Responsabilidades
7. **Uso Aceitável dos Recursos de TI**
8. **Uso Inaceitável e Atividades Proibidas**
 - 8.1 Violações de Acesso e Identidade
 - 8.2 Violações Técnicas
 - 8.3 Exfiltração e Uso Indevido de Dados
 - 8.4 Conduta Ética e Legal
 - 8.5 Medidas Disciplinares
9. **Gestão de Acessos e Senhas**
 - 9.1 Concessão e Controle de Acessos
 - 9.2 Uso e Proteção de Credenciais
 - 9.3 Requisitos e Troca de Senhas
 - 9.4 Revisão, Transferência e Revogação de Acessos
 - 9.5 Responsabilidade e Penalidades
10. **Política de Controle de Acesso (Resumo Operacional)**
11. **Segurança Física e do Ambiente**
12. **Segurança de Rede e Infraestrutura**
13. **Backup, Continuidade e Recuperação de Desastres**
14. **Gestão de Incidentes de Segurança da Informação**
15. **Conformidade Legal e Normativa**
16. **Sanções e Penalidades**
17. **Melhoria Contínua do SGSI**
18. **Termo de Concordância**
19. **Controle de Versão do Documento**
20. **Revisão do Documento**
21. **Anexos**
22. **Fontes de Pesquisa**

1. Objetivo

Este documento estabelece as normas de Segurança da Informação da Atlântica Financeira, com o objetivo de proteger seus dados e informações institucionais internas. Define diretrizes, responsabilidades e obrigações que devem ser observadas para assegurar o sigilo, a integridade e a disponibilidade das informações.

2. Âmbito / Abrangência

Esta Política de Segurança da Informação e Privacidade de Dados aplica-se a todos os colaboradores, prestadores de serviço, terceiros, parceiros e quaisquer pessoas que utilizem ou tenham acesso aos ativos de informação da Atlântica Financeira, independentemente do vínculo empregatício ou contratual.

3. Definições

- **Ativo de Informação:** Qualquer dado, sistema, equipamento ou recurso que possua valor para a organização.
- **Segurança da Informação:** Conjunto de medidas destinadas a proteger as informações contra acessos, alterações ou perdas não autorizadas.
- **Confidencialidade:** Garantia de acesso à informação apenas por pessoas autorizadas.
- **Integridade:** Garantia de que a informação permaneça correta e não seja alterada indevidamente.
- **Disponibilidade:** Garantia de que a informação esteja acessível quando necessária.
- **Dados Pessoais:** Informações relacionadas a pessoa natural identificada ou identificável, conforme legislação vigente.
- **Incidente de Segurança:** Evento que comprometa ou possa comprometer a segurança da informação.

4. Papéis e Responsabilidades

A segurança da informação na **Atlântica Financeira** é uma responsabilidade compartilhada entre a alta **administração, gestores, área de Tecnologia da Informação, usuários e terceiros**. Cada parte envolvida deve cumprir as diretrizes estabelecidas nesta Política, garantindo sua aplicação, manutenção e efetividade.

- A Alta administração é responsável pela aprovação da política e pelo apoio estratégico à segurança da informação.
- Os gestores asseguram o cumprimento das diretrizes em suas áreas.
- A área de TI é responsável pela implementação e monitoramento dos controles de segurança.

- Usuários e terceiros devem utilizar os recursos de informação de forma adequada e comunicar eventuais incidentes.
- Os responsáveis pela elaboração da política respondem por sua revisão e atualização

5. Divulgação e Declaração das Responsabilidades

A Política de Segurança da Informação e Privacidade de Dados será **divulgada a todos os usuários da organização** por meio de canais institucionais, incluindo e-mail corporativo, sistemas internos, treinamentos e, quando aplicável, meios impressos.

Os usuários deverão receber **treinamento obrigatório no mínimo anual**, bem como na integração inicial e sempre que houver atualizações relevantes, com registro formal de participação para fins de controle e auditoria.

Todos os colaboradores, **parceiros e terceiros deverão declarar formalmente ciência e concordância com esta Política**, por meio de termo assinado ou aceite eletrônico, sendo o aceite obrigatório e contratualmente previsto para terceiros.

O **descumprimento das diretrizes desta Política estará sujeito à aplicação de sanções proporcionais**, incluindo advertência, suspensão ou até mesmo uma justa causa, além das sanções legais cabíveis.

6. Classificação da Informação

As informações da organização devem ser **classificadas segundo sensibilidade, impacto ao negócio e requisitos legais**, garantindo uso, armazenamento, acesso e proteção adequados.

Níveis de classificação:

1. **Pública:**
Informações que podem ser divulgadas livremente, sem causar impacto à organização, clientes ou parceiros.
2. **Uso Interno:**
Informações destinadas ao uso interno, cujo acesso é restrito a colaboradores e terceiros autorizados.
3. **Confidencial:**
Informações sensíveis ao negócio, com acesso limitado a pessoas expressamente autorizadas. Divulgação indevida pode causar impacto operacional, financeiro ou reputacional.

- **Marcação:** Deve conter identificação explícita no cabeçalho ou rodapé (ex.: "CONFIDENCIAL").

4. **Restrita:**

Informações críticas ou sigilosas, incluindo dados pessoais sensíveis e estratégicos, com acesso altamente controlado e monitorado.

- **Descarte seguro:** Suportes físicos (papéis, HDs) devem ser destruídos seguindo procedimentos de destruição segura.

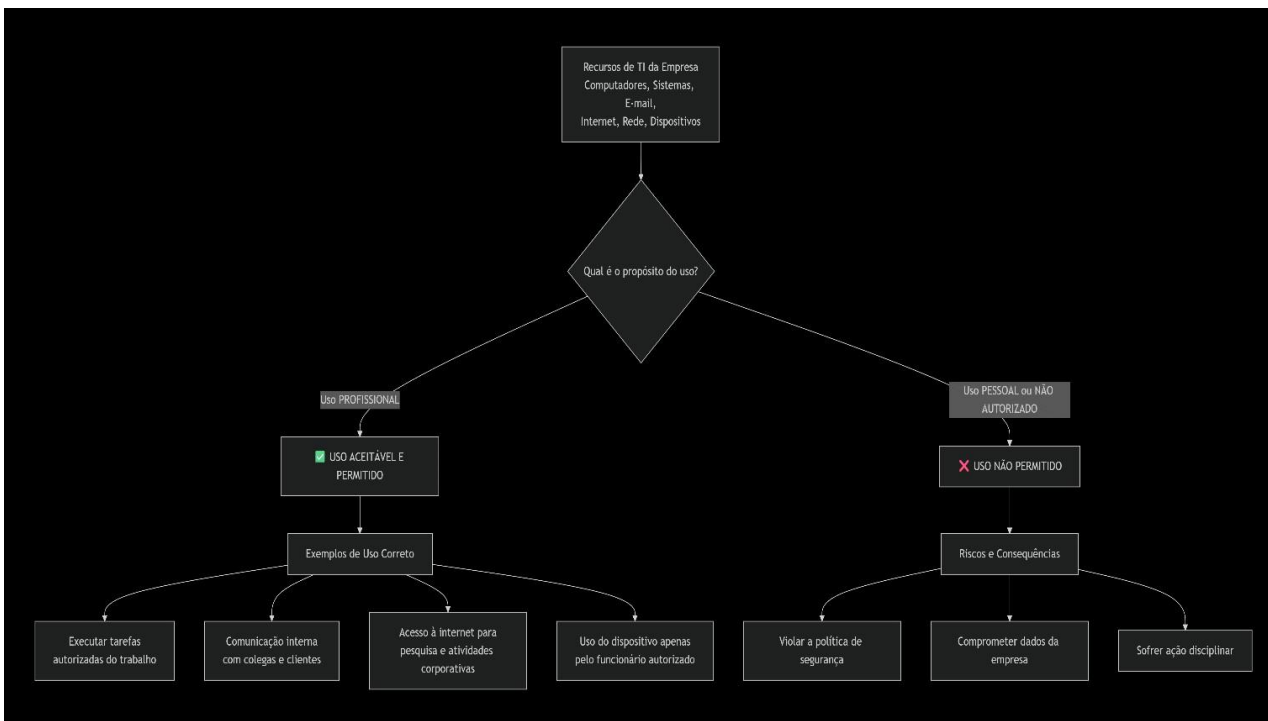
Propriedade da informação:

O gestor da área (Dono da Informação) define a classificação inicial dos dados produzidos em seu departamento.

Responsabilidade:

Todos os usuários devem obedecer à classificação das informações, garantindo tratamento, armazenamento e compartilhamento adequados.

7. **Uso Aceitável dos Recursos de TI**



Restrições:

- Instalar software não licenciado ou de origem desconhecida.
- Acessar ou distribuir conteúdo ilegais, ofensivos ou que comprometam a segurança.
- Compartilhar senhas ou informações sensíveis fora de ambientes autorizados.
- Uso pessoal que gere risco ou prejuízo à empresa.

Dispositivos móveis e BYOD:

- Só permitido com autorização prévia e seguindo requisitos de segurança (antivírus, bloqueio de tela).

Privacidade:

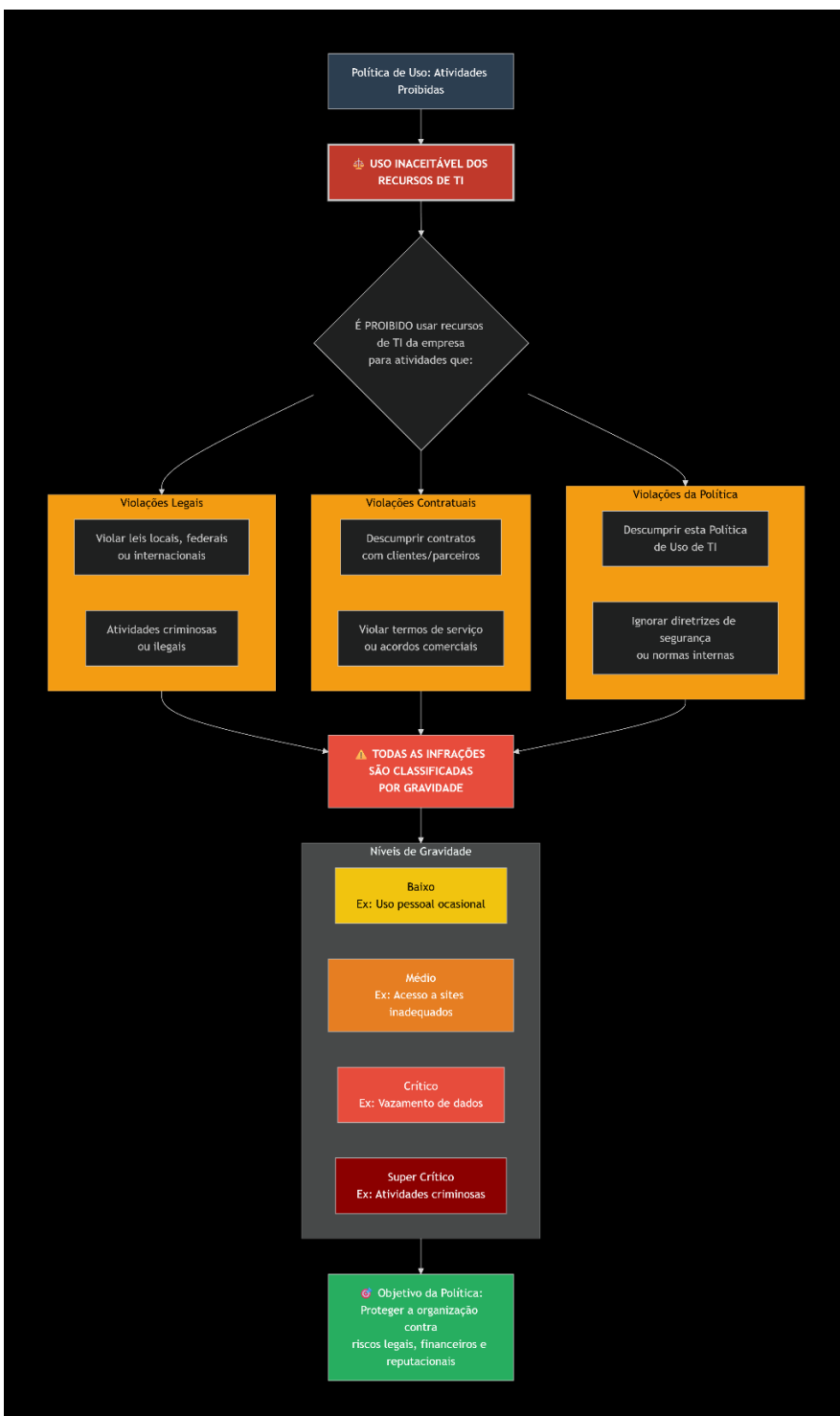
- A empresa pode monitorar e auditar todos os recursos de TI; não há expectativa de privacidade.

Responsabilidade:

- Usuários devem seguir a política, garantindo segurança e proteção dos ativos e informações corporativas.

8. Uso Inaceitável e Atividades Proibidas

É proibido o uso dos recursos de TI da organização para atividades que violem leis, contratos ou esta Política, sendo as infrações classificadas por gravidade:



8.1 Violações de Acesso e Identidade (Críticas)

- Compartilhar ou utilizar credenciais de terceiros.
- Acessar sistemas, dados ou redes sem autorização formal.

8.2 Violações Técnicas (Graves)

- Burlar ou desativar controles de segurança.
- Instalar software não licenciado, não homologado ou de origem desconhecida.
- Utilizar aplicações ou serviços não autorizados (Shadow IT).

8.3 Exfiltração e Uso Indevido de Dados (Críticos)

- Copiar ou transferir dados por dispositivos removíveis ou nuvem pessoal.
- Enviar informações Confidenciais ou Restritas para meios não autorizados.

8.4 Conduta Ética e Legal (Graves)

- Uso dos recursos para atividades ilegais, ofensivas ou antiéticas.
- Pirataria de software ou violação de direitos autorais.

8.5 Medidas Disciplinares

O descumprimento sujeita o infrator a sanções disciplinares, incluindo desligamento por justa causa e medidas legais.

9. Gestão de Acessos e Senhas

O acesso aos sistemas, redes e informações da organização deve seguir o princípio do menor privilégio, sendo concedido, revisado e revogado de forma controlada e rastreável.

9.1 Concessão e Controle de Acessos

- A concessão de acessos deve ser formalmente autorizada pelo gestor responsável e pela área de TI.
- Os acessos devem ser compatíveis com a função exercida.
- É proibido o uso de contas genéricas ou compartilhadas, salvo exceções formalmente aprovadas.

9.2 Uso e Proteção de Credenciais

- Credenciais de acesso são pessoais e intransferíveis.
- É proibido compartilhar, reutilizar ou registrar senhas em locais acessíveis a terceiros.
- Recomenda-se o uso de gerenciadores de senhas homologados pela organização para armazenamento seguro de credenciais.
- O usuário deve bloquear a estação de trabalho sempre que se afastar do equipamento, independentemente do tempo de ausência.

9.3 Requisitos e Troca de Senhas

- As senhas devem atender aos requisitos mínimos de complexidade definidos pela área de TI.
- Senhas temporárias fornecidas pelo TI devem ser alteradas no primeiro acesso.
- A senha deve ser alterada imediatamente em caso de suspeita de comprometimento.
- É proibida a reutilização de senhas corporativas em serviços pessoais.
- Sempre que disponível, deve ser utilizado mecanismo de autenticação multifator (MFA).

9.4 Revisão, Transferência e Revogação de Acessos

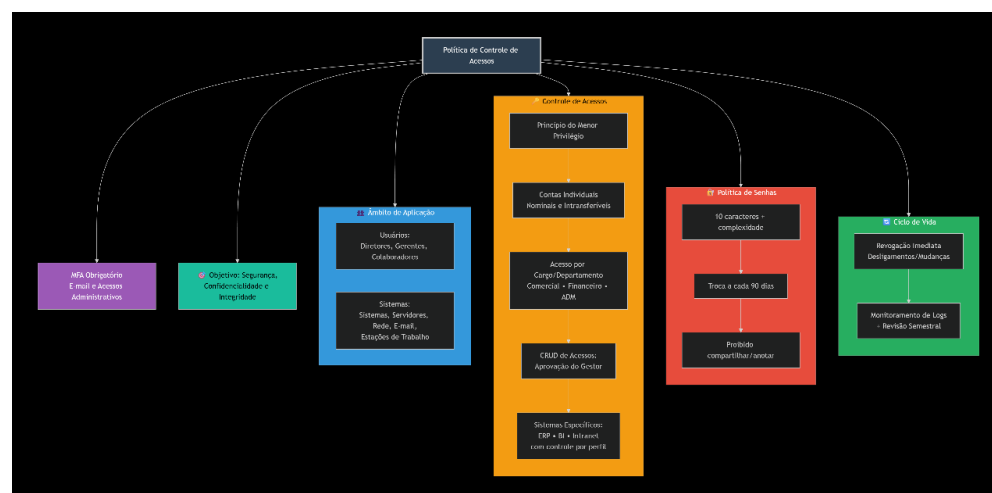
- Os acessos devem ser revogados imediatamente em casos de desligamento, término de contrato ou afastamento.
- Em caso de transferência de área ou função, os acessos da função anterior devem ser revogados antes da concessão de novas permissões.
- A área de TI deve realizar revisões periódicas dos acessos concedidos.

9.5 Responsabilidade e Penalidades

O descumprimento destas diretrizes poderá resultar em medidas disciplinares e legais, conforme a gravidade da infração.

10. Gestão de Acesso e senhas

Esta política de controle de acesso aplica-se a todos os usuários e recursos de TI, seguindo o princípio do menor privilégio por departamento. As contas são individuais e intransferíveis, com criação/modificação mediante aprovação gerencial. Senhas exigem alta complexidade, troca trimestral e é proibido compartilhá-las, sendo obrigatório MFA para e-mail e acessos administrativos. A revogação é imediata em desligamentos, com monitoramento contínuo de logs e revisão semestral dos acessos para garantir a segurança corporativa.



11. Segurança Física e do Ambiente

- A política aplica-se às **instalações físicas**, salas técnicas, racks, servidores, estações de trabalho e equipamentos de rede.
- O acesso físico às áreas críticas é **restrito a pessoas autorizadas**.
- **Salas de servidores e racks fechados** devem permanecer trancados e com acesso controlado.
- Racks abertos devem ficar em **áreas monitoradas e com acesso limitado**.
- O **servidor de CFTV** é de uso exclusivo da equipe autorizada (Segurança/ADM).
- Visitantes e terceiros devem ser **identificados, registrados e acompanhados** durante toda a permanência.
- Equipamentos de TI devem ser protegidos contra **roubo, danos, poeira, calor e umidade**.
- Ambientes críticos devem possuir:
 - Energia estabilizada (nobreaks).
 - Proteção contra surtos elétricos.
- Computadores devem ser **bloqueados quando não estiverem em uso**.
- É proibida a retirada de equipamentos sem **autorização formal**.
- Incidentes físicos (invasão, furto, falhas elétricas, incêndio) devem ser **reportados imediatamente**.
- O descumprimento da política pode resultar em **medidas disciplinares**.

12. Segurança de Rede e Infraestrutura

- A rede é **segmentada por departamento**, com 3 roteadores dedicados (1 por departamento) para isolar o tráfego e reduzir riscos.
- Existem 4 switches, com 1 rack fechado (área mais segura) e 3 racks abertos em áreas controladas para garantir proteção física da infraestrutura.
- O servidor de dados e o servidor de internet são protegidos por controles de acesso e configurados para minimizar vulnerabilidades.
- O acesso a dispositivos de rede (roteadores e switches) é restrito à equipe autorizada de TI, com uso de **credenciais fortes**.
- Todo o tráfego entre a rede interna e a internet é filtrado por firewall e regras configuradas para liberar somente o necessário.
- Serviços e portas não utilizados nos dispositivos de rede são desativados para evitar possíveis pontos de ataque.
- Configurações de equipamentos de rede são atualizadas regularmente, e backups das configurações são armazenados de forma segura.

- Logs de acesso e eventos de rede são registrados e monitorados periodicamente para identificar tentativas de acesso indevido ou falhas.
- A rede deve ser usada exclusivamente para fins corporativos, proibindo instalação de dispositivos ou serviços não autorizados.
- Incidentes envolvendo a rede devem ser reportados imediatamente para análise e correção.

13. Backup, Continuidade e Recuperação de Desastres

- Backups diários dos servidores e sistemas críticos (ERP, BI) são obrigatórios.
- Dados e backups de configurações devem ser armazenados em local seguro, preferencialmente fora do ambiente principal.
- Backups são testados regularmente para garantir a restauração.
- Plano de Continuidade de Negócios mantém operações mínimas durante falhas, com equipe treinada e infraestrutura de energia (nobrek).
- Plano de Recuperação de Desastres documentado define ações, responsáveis e prazos para restabelecer sistemas após incidentes graves.
- Testes regulares do plano garantem sua efetividade.
- Incidentes relacionados devem ser reportados imediatamente.
- O descumprimento das diretrizes pode acarretar sanções disciplinares.

14. Gestão de Incidentes de Segurança da Informação

- Todos os incidentes ou suspeitas devem ser **imediatamente reportados** à equipe de TI.
- Incidentes são registrados com detalhes para análise.
- A equipe de segurança avalia o incidente, contendo e mitigando impactos rapidamente.
- Comunicação clara é feita com gestores e, se necessário, autoridades externas.
- Ações corretivas são implementadas para recuperar sistemas e prevenir reincidência.
- Colaboradores são treinados para identificar e reportar incidentes.
- O descumprimento pode levar a medidas disciplinares.

15. Conformidade Legal e Normativa

Para garantir que a empresa cumpra todas as **leis, regulamentos, normas e padrões aplicáveis**

Aplica-se:

- **LGPD (Lei Geral de Proteção de Dados)** – proteção de dados pessoais.
- **ISO/IEC 27001/27002** – gestão de segurança da informação.
- **NIST** – boas práticas de cibersegurança.
- **PCI DSS** – proteção de dados de cartões de pagamento (quando aplicável).
- Outras legislações locais e regulamentações setoriais pertinentes.

16. Sanções e Penalidades

Tipos de Descumprimento Acesso não autorizado a sistemas ou dados.

- **Compartilhamento de senhas** ou credenciais.
- **Violação de normas legais e regulamentares** (LGPD, ISO, PCI DSS etc.).
- **Uso indevido da rede ou recursos corporativos.**
- **Não reporte de incidentes de segurança** ou falhas.

Consequências / Penalidades/Advertência verbal ou escrita – para infrações leves ou primeiras ocorrências. **Suspensão de acessos** – bloqueio temporário de sistemas ou recursos. **Treinamento corretivo** – reorientação sobre as políticas e boas práticas. **Medidas disciplinares formais** – incluindo suspensão, demissão ou responsabilização legal, conforme normas internas e legislação vigente.

17. Melhoria Contínua do SGSI

A Política de Segurança da Informação e o SGSI devem ser **revisados periodicamente**, ou sempre que houver mudanças significativas em sistemas, processos ou legislação. **Auditorias internas e externas** são realizadas para verificar conformidade e identificar oportunidades de melhoria. Controles, procedimentos e treinamentos devem ser **atualizados** com base em incidentes, auditorias, novas ameaças ou mudanças legais. Indicadores de desempenho e métricas devem ser monitorados para orientar ações corretivas e preventivas. Colaboradores participam da melhoria contínua por meio de **feedback e capacitação constante**. O objetivo é garantir que o SGSI evolua continuamente, mantendo a **confidencialidade, integridade e disponibilidade** das informações e mitigando riscos.

18. Termo de Concordância

TERMO DE CONCORDÂNCIA E CIÊNCIA **Atlântica Financeira**

Li e estou de acordo com as diretrizes da Política de Segurança da Informação (P-SGSI-001) e da Política de Uso do Acesso Corporativo da Atlântica Financeira.

Estou ciente de que o descumprimento constitui infração disciplinar, sujeita às medidas da **CLT (Art. 482)**, podendo acarretar também responsabilização **civil (Código Civil)**, **administrativa (LGPD)** e **penal (Leis 12.737/2012 e Código Penal)**, além de indenizações por danos causados.

Este termo é firmado em duas vias, ficando uma com o colaborador e outra com a empresa.

Data: ____/____/____

Nome: _____

Assinatura: _____

Local e Data

Assinatura

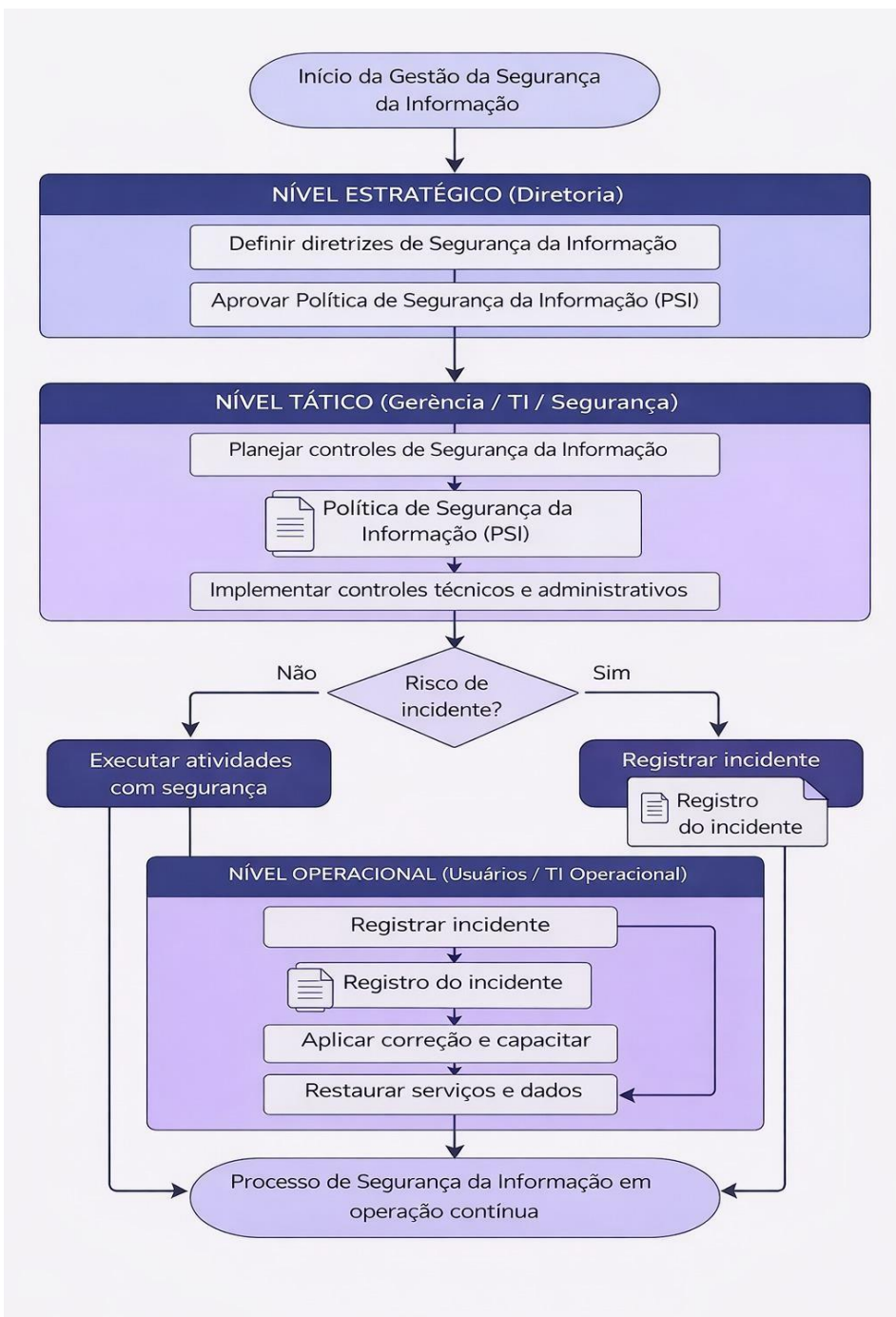
19. Controle de Versão de Documento

Versão	Data	Autor	Comentários
01	04/02/2026	Security Solution	Versionamento/documento

20. Revisão do Documento

Revisão	Data	Revisor	Comentários
1	10/02/2026	Náthani Marins	Revisor do Documento
2	10/02/2026	Paulo Martins	Revisor do Documento
3	10/02/2026	Pablo Haddad	Revisor do Documento

21. Anexos



MATRIZ DE RISCO

ATLANTICA FINANCEIRA

ID	Área	Risco	Categoria	Probabilidade (1)	Impacto (1)	Nível de Risco (P)	Classificação E	Controles/Mitigação	Classificação GERAL
1	TI	Vazamento de dados financeiro	Segurança da Informação	5	5	25	Super crítico	Criptografia, DLP, MFA	Crítico
2	TI	Ataque ransomware	Cibernético	4	5	20	Super crítico	Backup offline, EDR, conscientização	Crítico
3	TI	Acesso indevido a sistemas	Controle de Acesso	3	5	15	Crítico	IAM, MFA, revisão periódica	Super crítico
4	TI	Shadow IT	Governança	3	4	12	Crítico	Bloqueio, política e conscientização	Médio
5	Operacional	Erro humano em transações	Operacional	3	4	12	Crítico	dupla checagem, segregação de funções	Médio
6	Financeiro	Fraude interna	Fraude	2	5	10	Médio	Auditoria, segregação de funções	Crítico
7	Financeiro	Fraude externa	Fraude	4	5	20	Super crítico	Monitoramento, antifraude	Crítico
8	Compliance	Não conformidade com LGPD	Legal/Regulatório	3	5	15	Crítico	Governança de dados, DPO	Crítico
9	Compliance	Não conformidade BACEN	Regulatório	2	5	10	Médio	Compliance contínuo	Crítico
10	RH	Engenharia social / Phishing	Humano	4	4	16	Super crítico	Treinamentos e simulações	Super crítico
11	Infraestrutura	Indisponibilidade de sistemas	Continuidade	3	5	15	Crítico	Alta disponibilidade, DRP	Super crítico
12	Infraestrutura	Falha de backup	Continuidade	2	5	10	Médio	Testes periódicos	Médio
13	Jurídico	Quebra de sigilo bancário	Legal	2	5	10	Médio	Controles de acesso	Crítico
14	Terceiros	Vazamento por fornecedor	Terceiros	3	5	15	Crítico	Due diligence, contratos	Super crítico
15	Físico	Acesso físico não autorizado	Segurança Física	2	4	8	Médio	Controle de acesso físico	Médio



Responsável



SECURITY SOLUTIONS

Equipe:

Pablo Haddad
Nathani Marins
Paulo Martins

Distribuição da equipe Encarregados de cada tema		
Pablo Haddad	Paulo Martins	Nathani Marins
Matriz de risco	Estruturação do arquivo da política da segurança da informação	Diagrama de processos
Fontes dos tópicos		Conteúdo do slide/tópicos
Desenvolvimento dos tópicos 1 a 10 da política da segurança da informação	Revisão e alteração do arquivo da política da segurança da informação	Desenvolvimento dos tópicos 10 a 20 da política da segurança da informação
Estruturação do slide	Estrutura dos capítulos e subcapítulos do arquivo da política da segurança da informação	

22. Fontes de Pesquisa

ISO/IEC 27001 – Sistema de Gestão de Segurança da Informação

Fonte oficial:

<https://www.iso.org/isoiec-27001-information-security.html>

Por que utilizar: Estabelece a estrutura de gestão e governança da segurança da informação baseada em riscos.

Empresas que utilizam:

- Microsoft
- IBM
- Santander

ISO/IEC 27002 – Controles de Segurança da Informação

Fonte oficial:

<https://www.iso.org/standard/75652.html>

Por que utilizar: Define controles e boas práticas para proteção dos ativos de informação.

Empresas que utilizam:

- Oracle
- Accenture
- Banco do Brasil

NIST Cybersecurity Framework (CSF)

Fonte oficial:

<https://www.nist.gov/cyberframework>

Por que utilizar: Auxilia na gestão de riscos e resposta a incidentes de segurança cibernética.

Empresas que utilizam:

- Google
- Amazon
- JPMorgan Chase

Lei Geral de Proteção de Dados (LGPD – Lei nº 13.709/2018)

Fonte oficial:

https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm

Por que utilizar: Garante conformidade legal no tratamento de dados pessoais.

Empresas que utilizam:

- Itaú Unibanco
- Nubank
- Magazine Luiza

PCI DSS – Payment Card Industry Data Security Standard

Fonte oficial:

<https://www.pcisecuritystandards.org>

Por que utilizar: Protege dados de cartões e transações financeiras.

Empresas que utilizam:

- Visa
- Mastercard
- PayPal

Monitoramento e Correlação de Eventos de Segurança (SIEM)

- A organização utiliza uma solução de **monitoramento centralizado de eventos de segurança (SIEM)** para coleta, correlação e análise de logs provenientes de sistemas, servidores, bancos de dados, aplicações, dispositivos de rede e controles de segurança.
- Essa solução permite:
- Monitoramento contínuo das atividades realizadas na infraestrutura tecnológica;
- Registro e análise de acessos de usuários, tentativas de acesso indevido e alterações em sistemas críticos;
- Identificação de comportamentos anômalos, atividades suspeitas e possíveis fraudes;
- Suporte à detecção precoce e resposta a incidentes de segurança da informação;
- Apoio a auditorias internas, investigações e requisitos regulatórios.
- Os registros (logs) são armazenados de forma segura, com **controle de acesso restrito**, integridade garantida e retenção definida conforme requisitos legais, normativos e regulatórios aplicáveis ao setor financeiro.
- Como exemplo de ferramenta de mercado amplamente utilizada, pode-se citar o **Splunk Enterprise Security**, solução reconhecida internacionalmente para monitoramento, correlação de eventos e apoio à conformidade com normas como **ISO/IEC 27001, ISO/IEC 27002, LGPD e regulamentações do BACEN**.

Criado e Desenvolvido pelos integrantes Pablo Haddad, Náthani Marins, Paulo Martins,
Empresa Security Solutions